

Contents

1	権限設計書 (メイン)	1
1.1	1. 文書概要	1
1.1.1	1.1 目的	1
1.1.2	1.2 対象範囲	1
1.1.3	1.3 版数	1
1.1.4	1.4 関連ドキュメント	1
1.2	2. ロール一覧	2
1.3	3. ロール定義(account_project_grants.role 2 値 + オーナー)	2
1.3.1	3.1 ロール概要	2
1.3.2	3.2 ロール × 主管 SCR / FR 対応	2
1.3.3	3.3 オーナー専有機能(プロジェクト別ロールでは付与不可)	2
1.4	4. 画面別権限マトリクス	3
1.5	5. 機能別権限	3
1.6	6. API 別権限	4
1.7	7. 契約別利用制限 / 運営者上書き	5
1.7.1	7.1 単一プランの利用上限 (11_課金請求設計書.md §3 参照)	5
1.7.2	7.2 80/100/125% 三段階アクション (11_課金請求設計書.md §8 の参照)	5
1.8	8. 権限不足・契約上書き時の動作	5
1.9	9. 緊急時のみ可操作 (§3.2.1-2 から移管)	6
1.9.1	9.1 「△ 緊急時のみ可」操作の発動条件	6
1.9.2	9.2 緊急区分 × 検知ハンドラ × 承認 SLA	6
1.10	10. 未決事項	7
1.11	11. 変更履歴	7

1 権限設計書 (メイン)

1.1 1. 文書概要

1.1.1 1.1 目的

メインシステムの権限モデル(オーナー / プロジェクト管理者 / メンバー / エンドユーザー / 運営者)、プロジェクト別ロール 2 値、画面別・機能別・API 別の操作可否、**契約別利用上書き** を一元化する。

1.1.2 1.2 対象範囲

- 対象: 利用者の契約ロール(`accounts.role=admin/service_operator/end_user`)、プロジェクト別ロール(`account_project_grants.role=admin/member`)、オーナー専有機能、契約別利用上書き
- 対象外: 運営者ロール(02_運営者システム/個別設計書群/05_権限設計書.md 参照)、認証フロー(09_認証認可設計書.md 参照)

1.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

1.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_索引.md
認証・認可設計書	認可判定ロジック / Principal	09_認証認可設計書.md
画面設計書	画面別表示制御	02_画面設計書.md
API 設計書	API 別権限	03_API 設計書.md
課金・請求設計書	契約別利用上書き (owner_quota_overrides 等)	11_課金請求設計書.md
エラー設計書	権限不足時のエラー	06_エラー設計書.md
テーブル定義書	account_project_grants.role(プロジェクト別ロール 2 値)	04_テーブル定義書.md

1.2 2. ロール一覧

利用者側は3つのロール(オーナー/プロジェクト管理者/メンバー)で構成する。プロジェクト管理者とメンバーは「プロジェクト単位」のロールであり、同一メンバーがプロジェクト A では **admin**、プロジェクト B では **member**、プロジェクト C には未割当、といった組合せをとり得る。

ロール ID	ロール名	概要	DB 値
OWNER	オーナーアカウント	契約あたり1アカウント固定、全プロジェクトの暗黙の admin 相当 + オーナー専有機能。 account_project_grants に行を持たない	accounts.role='admin' AND is_owner=1 AND owner_account_id=id
PROJECT_ADMIN	プロジェクト管理者	該当プロジェクトに対する admin ロール保持メンバー。複数プロジェクト兼任可	accounts.is_owner=0 AND account_project_grants.role='admin'(プロジェクト単位)
MEMBER	メンバー	該当プロジェクトに対する member ロール保持メンバー	accounts.is_owner=0 AND account_project_grants.role='member'(プロジェクト単位)
END_USER	エンドユーザー	ウィジェット利用者(自分の問い合わせ ID のみ)	accounts.role='end_user'
SERVICE_OPERATOR	運営者	本 SaaS 提供者(運営者側)	accounts.role='service_operator'

用語の衝突回避: `accounts.role='admin'` は契約上の利用者管理者を表す DB 値で、すべての利用者アカウント(オーナー/メンバー双方)で `'admin'`(= `service_operator` / `end_user` ではない)。一方 `account_project_grants.role='admin'` はプロジェクト管理者ロールを示す。本書では文脈区別のため必ず `accounts.role` / `account_project_grants.role` のように修飾する。

1.3 3. ロール定義 (account_project_grants.role 2 値 + オーナー)

1.3.1 3.1 ロール概要

ロール	表示名 (UI)	範囲	できること
オーナー	オーナー	契約全体	プロジェクトの作成・編集・削除、IP 許可リスト、許可ドメイン等のプロジェクト設定全般、課金、退会、規約再同意、メンバー招待・編集・削除、全プロジェクトの FAQ / 個別チャット / ログ参照(暗黙の admin 相当)
admin	プロジェクト管理者	該当プロジェクト	FAQ 登録・編集・公開、未解決質問対応・チャット返信、ログ参照、データエクスポート、該当プロジェクトへのメンバー招待・離脱・ロール変更(操作者自身が admin のプロジェクト内に限る)
member	メンバー	該当プロジェクト	FAQ 登録・編集・公開、未解決質問対応・チャット返信、ログ参照、データエクスポート(該当プロジェクト範囲)

オーナーは `account_project_grants` に行を持たず、Principal 構築時に `is_owner=1` 判定で認可チェックを bypass する(詳細は [09_認証認可設計書.md § 6.1](#))。

1.3.2 3.2 ロール × 主管 SCR / FR 対応

ロール	主な操作対象 SCR / FR
オーナー	全 SCR、FR-015a / FR-015c / FR-030 / FR-030a / FR-030b / FR-035a / FR-115～127(課金) / FR-189(退会) / FR-179 / FR-193(API キー) / 規約
admin(プロジェクト管理者)	SCR-010 / 011 / 012 / 013 / 015(該当プロジェクト範囲) / SCR-017 / SCR-017-M1(操作者が admin のプロジェクト範囲) / FR-015 / FR-016 / FR-018a～c / FR-040～046 / FR-070～079 / FR-086 / NFR-602 系列
member	SCR-001(ダッシュボード) / SCR-011 / 012 / 013 / 015(該当プロジェクト範囲) / FR-040～046 / FR-070～079 / FR-086(返信のみ)

1.3.3 3.3 オーナー専有機能 (プロジェクト別ロールでは付与不可)

- プロジェクトの作成・編集・削除(SCR-010 / SCR-010-M1、許可ドメイン、IP 許可リスト等のプロジェクト設定全般を含む)

- ・課金 (SCR-015 の月次予算変更 / 支払い方法変更)
- ・退会 (SCR-024)
- ・規約再同意 (SCR-025 の同意 / 不同意)
- ・メンバーアカウント完全削除 (DELETE /members/{id})—— プロジェクト管理者は「離脱」(account_project_grants 行の削除)のみ可

UI 上は非表示 + API は 403(E-AUTHZ-OWNER-ONLY)。

1.4 4. 画面別権限マトリクス

凡例: ○ = 常時可、△ = 「緊急時のみ可」 (§9 参照)、自分のみ = 自分の問い合わせ ID 範囲内のみ、× = 不可
プロジェクト管理者 / メンバー列は「該当プロジェクト割当ありかつそのロール保持時」の挙動を表す。

操作分類	オーナー	プロジェクト管理者 (該当 PJ)	メンバー (該 当 PJ)	end_us	service_operator
ダッシュボード (自分の通知・お知らせ 受信箱)	○	○	○	×	×
FAQ 登録・編集・公開	○	○	○	×	△(運営者復元時のみ)
プロジェクト作成・編集・削除	○(専有)	×	×	×	△(運営者復元時のみ)
プロジェクト IP 許可リスト編集 (FR-179 / FR-330)	○(専有)	×	×	×	×
プロジェクト設定閲覧 (IP 許可リスト含む)	○	○	○	×	×
メンバー招待・該当 PJ 離脱・該当 PJ 内 ロール変更	○	○	×	×	×
メンバー全 PJ 一括ロール変更 / アカウ ント完全削除	○(専有)	×	×	×	×
未解決質問閲覧・対応・担当割当	○	○	○	×	△(障害調査時のみ)
個別チャット返信	○	○	○	自分のみ	×
個別チャット閲覧	○	○	○	自分のみ	△(障害調査時のみ)
質問ログ閲覧	○	○	○	×	×
監査ログ閲覧 (自契約)	○	○	○	×	○(全契約)
課金情報閲覧・変更	○(専有)	×	×	×	△(訂正・サポート時のみ)
退会申請・解約	○(専有)	×	×	×	×
規約再同意の承諾	○(専有)	×	×	×	×
データエクスポート	○	○	○	×	×
契約無効化 (サスペンション)	×	×	×	×	○
契約物理削除	×	×	×	×	○(退会後の自動バッチ)
プロンプトテンプレート編集	×	×	×	×	○(運営者のみ)
案件「終了」確定	○	○	○	×	×
案件「解決済み」	○	○	○	×	×
お知らせ閲覧 (自契約)	○	○	○	×	△(運用調査時のみ)
お知らせ既読化	○	○	○	×	×
お知らせ作成・配信	×	×	×	×	○
critical 通知 (ロックアウト 等) 受信	○	○	×	×	×

1.5 5. 機能別権限

機能 ID	機能名	必要ロール	オーナー	制限事項
F-AUTH-*	認証	不要	○	-
F-PRJ-*	プロジェクト管理 (作成・編集・削除)	オーナー専有	○	削除は再認証必須
F-FAQ-*	FAQ 管理	member+(該当 PJ)	○	公開ガード (draft → published 直接遷移禁止)
F-INQ-*	未解決質問	member+(該当 PJ)	○	closed 遷移は admin の明示操作のみ (FR-079)
F-CHAT-*	個別チャット	member+(該当 PJ)	○	部屋クローズ / 再オープンは再認証必須
F-WIDGET-*	ウィジェット設定	オーナー専有	○	API キーローテーションは再認証必須
F-BILL-*	課金	オーナー専有	○	月次予算変更は再認証必須
F-USER-*	ユーザー管理 (招待・離脱・ロール変更)	admin+(該当 PJ) / オーナー (契約全体)	○	招待 / 編集 / 招待再送 / 離脱 / 削除は再認証必須。アカウント完全削除はオーナー専有
F-ACC-*	アカウント設定 / 退会	オーナー専有	○	退会は再認証必須
F-NOTIF-*	お知らせ	全 admin	○	既読化のみ
F-LEGAL-*	規約 / 同意	オーナー専有 (同意) / 全ユーザー (閲覧)	○	-

「member+(該当 PJ)」は該当プロジェクトに対するロールが **member** または **admin** であることを示す (オーナーは bypass)。「admin+(該当 PJ)」は該当プロジェクトに対するロールが **admin** のみを示す。

1.6 6. API 別権限

03_API 設計書.md を正本とする。主要 API:

API	メソッド	必要ロール	オーナー専有	再認証	関連エラー ID
POST /auth/login	POST	不要	-	-	E-AUTH-*
POST /projects	POST	オーナー専有	○	-	E-AUTHZ-OWNER-ONLY
PATCH /projects/{id}	PATCH	オーナー専有	○	-	E-AUTHZ-OWNER-ONLY
DELETE /projects/{id}	DELETE	オーナー専有	○	○	E-AUTHZ-OWNER-ONLY
PATCH /projects/{id}/ip-allowlist	PATCH	オーナー専有	○	-	E-AUTHZ-OWNER-ONLY
POST /faqs / PATCH / DELETE	*	member+(該当 PJ)	-	DELETE のみ ○	-
POST /faqs/{id}/publish	POST	member+(該当 PJ)	-	-	E-BIZ-FAQ-PUBLISH(公開ガード)

API	メソッド	必要ロール	オーナー専有	再認証	関連エラー ID
POST /inquiries/{id}/close	POST	member+(該当 PJ)	-	○	-
POST /chat-rooms/{id}/close	POST	member+(該当 PJ)	-	○	-
GET /usage / GET /billing/invoices	GET	オーナー専有	○	-	E-AUTHZ-OWNER-ONLY
PATCH /billing/monthly-budget-limit	PATCH	オーナー専有	○	○	-
POST /members/invite	POST	admin+(該当 PJ)/ オーナー	-	○	E-AUTHZ-OWNER-PROTECTED
POST /members/{id}/project-grants	POST	オーナー専有 (契約全体上書き)	○	○	E-AUTHZ-LAST-ADMIN-PROTECTED
POST /projects/{id}/members	POST	admin+(該当 PJ)/ オーナー	-	○	-
DELETE /projects/{id}/members/{accountId}	DELETE	admin+(該当 PJ)/ オーナー	-	○	E-AUTHZ-LAST-ADMIN-PROTECTED
DELETE /members/{id}	DELETE	オーナー専有	○	○	E-AUTHZ-OWNER-ONLY
POST /withdrawal-requests	POST	オーナー専有	○	○	-
POST /terms/agree	POST	オーナー専有 (承諾)	○	-	-

1.7 7. 契約別利用制限 / 運営者上書き

1.7.1 7.1 単一プランの利用上限 (11_課金請求設計書.md §3 参照)

MVP は単一プラン (完全従量課金 + 月次無料枠 + 14 日トライアル)。プラン階層による差別化はない。利用上限は **owner_quota_overrides.resource_kind** で統一実装される (テーブル定義書 04 § 3.26 参照)。

resource_kind	用途	主管 SCR(運営者)
widget_ask_per_min	ウィジェット質問レート	SCR-093
widget_inquiry_per_min	ウィジェット未解決質問送信レート	SCR-093
widget_chat_per_min	ウィジェットチャット投稿レート	SCR-093
email_per_hour	メール送信レート	SCR-093
admin_api_per_min	管理 API レート	SCR-093

1.7.2 7.2 80/100/125% 三段階アクション (11_課金請求設計書.md §8 の参照)

データ種別	80%	100%	125%
質問数	inbox 通知 (normal)	inbox + email(high)、拒否しない (事後課金)	翌 1 時間レート制限 1/2 + 運営者エスカレーション
FAQ 件数	inbox 通知	新規登録拒否 (編集可)	+ 運営者エスカレーション
個別チャット部屋数	inbox 通知	新規作成拒否 (返信可)	+ 運営者エスカレーション

詳細は 11_課金請求設計書.md §8 を正本とする。

1.8 8. 権限不足・契約上書き時の動作

ケース	システム動作	画面表示	メッセージ ID	関連エラー ID
ロール不足 (member で admin 限定操作を試行)	403 統一	「権限がありません」 + オーナー / 該当プロジェクト管理者へ連絡誘導	MSG-COMMON-AUTHZ-403	E-AUTHZ-FORBIDDEN
オーナー境界違反 (他契約のリソース参照)	404 偽装 (403 だと相手契約の存在が漏れる)	「リソースが見つかりません」	MSG-COMMON-NOT-FOUND	E-AUTHZ-OWNER-BOUNDARY
プロジェクト割当不足 (account_project_grants に行なし)	404 偽装	「リソースが見つかりません」	MSG-COMMON-NOT-FOUND	E-AUTHZ-PROJECT-DENIED
オーナー専有機能 (is_owner=0 でアクセス)	403 + 専用コード、UI 非表示	「この機能はオーナーのみご利用いただけます」	MSG-COMMON-OWNER-ONLY	E-AUTHZ-OWNER-ONLY
オーナー保護違反 (オーナー停止 / 削除)	403	「オーナーアカウントは停止・削除できません」	MSG-COMMON-OWNER-PROTECTED	E-AUTHZ-OWNER-PROTECTED
自己操作不可 (自分が admin を持つ最後のプロジェクトで自身を降格 / 割当解除)	403、UI 非活性	「あなたが最後の管理者です。先に他の管理者を割当してください」	MSG-COMMON-SELF-MUTATION	E-AUTHZ-SELF-MUTATION
最後の管理者保護 (他者をプロジェクトの最後の admin から外す)	403	「このプロジェクトの最後の管理者は外せません。先に他の管理者を割当してください」	MSG-COMMON-LAST-ADMIN	E-AUTHZ-LAST-ADMIN-PROTECTED
契約停止中 (contract_status=suspended)	403 + 専用コード、課金画面 / 退会画面 / データエクスポートのみ許可	サスペンション理由 + 再決済誘導	MSG-BILL-CONTRACT-SUSPENDED	E-BIZ-CONTRACT-SUSPENDED
月次無料枠 100% 超過 (質問数以外)	429 + Retry-After	「上限に到達しました」 + 課金ダッシュボード誘導	MSG-QUOTA-*	E-BIZ-QUOTA-EXCEEDED

詳細は [06_エラー設計書.md §5](#) を正本とする。

1.9 9. 緊急時のみ可操作 (§3.2.1-2 から移管)

1.9.1 9.1 「△ 緊急時のみ可」 操作の発動条件

条件	実装方針 (メイン側)
1. サポートチケット ID 必須	連携 IF #4 / #5 / #6 / #12 のリクエスト JSON に ticket_id フィールドを必須化。メイン側で空文字検証 + 監査ログ記録
2. 運営者 2 名の承認 (自己承認不可)	顧客管理側で承認を取得し、結果を連携 IF 経由で伝搬。メイン側はメタフィールド approvals[] (承認者 2 名分) の検証 (承認者 ID が異なる、承認時刻が 24 時間以内、kid 検証) を実施
3. 管理者ユーザーへの即時通知	メイン側で inbox_messages レコードを生成 (category=system、importance=high) + メール送信を Queue 投入
4. 監査ログ必須記録	<resource>.<verb>.by_operator 形式の action コードで audit_logs に記録。retention_class=operator_high_priv(5 年保持)

1.9.2 9.2 緊急区分 × 検知ハンドラ × 承認 SLA

緊急区分	検知ハンドラ	承認 SLA	エスカレーション経路
重大障害	monitoring:main_outage 監視 / 連携 IF #2 ヘルスチェック (5s × 3 連続失敗)	15 分以内に 2 名承認	RB-021(メイン障害時の運営者側縮退運転) と連動
全員ロックアウト	audit_logs(auth.locked) 集約検知 (該当契約内全 admin が auth.locked 状態)	30 分以内に CS マネージャーへ通報	サポート窓口経由でオーナーと連絡、紙ベース回復コード (RB-014) も可
セキュリティインシデント	NFR-602c 監査ログ完全性検証バッチ / SIEM / 不正アクセス検知 (FR-178)	即時 PagerDuty 起動	セキュリティ責任者 → CTO → 運営本部
法令対応	(運用側で個別判断)	個別判断	法務 → CTO

1.10 10. 未決事項

No	内容	確認先	期限	ステータス
----	----	-----	----	-------

1.11 11. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude